

基于机器学习算法的 WEB 应用程序漏洞检测策略

王 彬,蒋铭初,周 进,李晓禹,陈泽翰

(中国电子科技集团公司第二十八研究所,江苏 南京)

摘 要:随着 WEB 应用程序的普及,对其安全性的关注日益增加。漏洞检测作为保障 WEB 应用程序安全的关键手段之一备受重视。本文综合了多种漏洞检测方法,提出了基于机器学习算法的 WEB 应用程序漏洞检测策略。通过结合敏感性分析、静态信息流跟踪和双向数据流分析等步骤,本文设计了一个综合性的漏洞检测方法,并在测试环境下取得了 98%准确率的优异表现。

关键词:支持向量机;漏洞扫描;检测策略

中图分类号:TP181;TP311

文献标识码:A

文章编号:2096-4390(2025)15-0083-04

引言

随着 WEB 应用程序的不断发展和普及,对其安全性的关注也日益增加。漏洞检测作为确保 WEB 应用程序安全的重要手段之一,吸引了广泛的关注和研究。王泽旭和文斌提出了一种基于关键路径预搜索的符号执行方法,以优化智能合约漏洞检测效率^[1]。冯青文等介绍了一种基于 LSTM-SVM 算法的软件潜在溢出漏洞检测方法,实现了较高的检测率和准确率,同时降低了检测时间和性能消耗^[2]。郑鹏和沙乐天提出了一种基于符号执行和污点分析的自动检测方法,通过 Taint Gadget 工具实现 Java 反序列化漏洞的静态和动态检测^[3]。况博裕等提出了一种基于人机协同的物联网设备固件漏洞挖掘方案 HMFuzzer,设计了基于设备固件前后端交互的设备固件关键信息提取方法,通过模拟设备固件、设备管理界面以及用户三方交互模式获取固件潜在的关键信息,并通过二进制文件定位和函数分析技术解析出固件关键函数^[4]。徐寅森等提出了一种基于机器学习的传感网核心节点漏洞检测方法,利用支持向量机树形多分类器获取核心节点的位置,采取主成分分析法提取核心节点特征,将其输入到 LSTM 长短记忆神经网络模型中,并利用滑动窗口与哈希函数训练漏洞检测分类模型,完成传感网核心节点的漏洞检测^[5]。李鑫等介绍了一种基于双通道结构并整合多种神经网络技术以及注意力机制的

智能合约漏洞检测方法。该方法在处理两种不同类型的智能合约漏洞时表现出较高精度^[6]。研究者们通过引入符号执行方法、深度学习算法、符号执行和污点分析等技术,提出了一系列创新的漏洞检测方法,在智能合约、Java 反序列化、源代码漏洞和区块链智能合约等领域取得了显著成果。本文也基于此探讨了运用机器学习算法的漏洞检测策略。

1 漏洞检测策略设计

1.1 输入验证漏洞

WEB 应用程序的安全性一直备受关注,由于存在各种潜在的安全漏洞,其中输入验证问题是最常见且具有严重影响类型之一。输入验证漏洞是由于未正确验证或处理用户输入而导致的安全问题,攻击者可以利用输入验证漏洞来篡改数据、执行恶意代码或获取敏感信息,从而危害用户和系统的安全。输入验证漏洞如表 1 所示。

表 1 输入验证漏洞

类型	描述
SQL 注入	攻击者通过构造恶意 SQL 语句将恶意代码注入到数据库查询中,这可能导致数据库泄露、数据篡改或执行未经授权的操作
跨站脚本 (XSS)	攻击者向 WEB 页面插入恶意脚本代码,使得用户在浏览器上执行该代码,这可能导致用户会话劫持、信息窃取以及其他恶意行为
文件包含漏洞	允许攻击者包含外部文件并执行其中的代码,这可能导致系统文件泄露、任意代码执行以及系统完整性受损

1.2 信息流分析

数据流分析方法是一种重要的静态代码分析技

作者简介:王彬(1990-),男,硕士研究生,工程师,研究方向:网络信息安全。

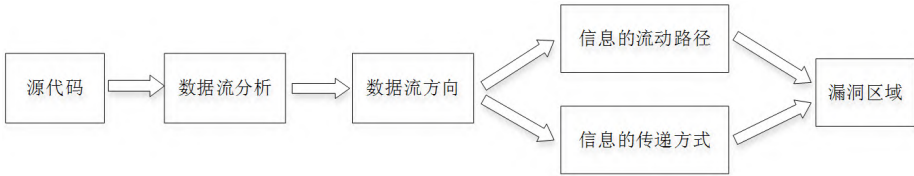


图1 信息流分析

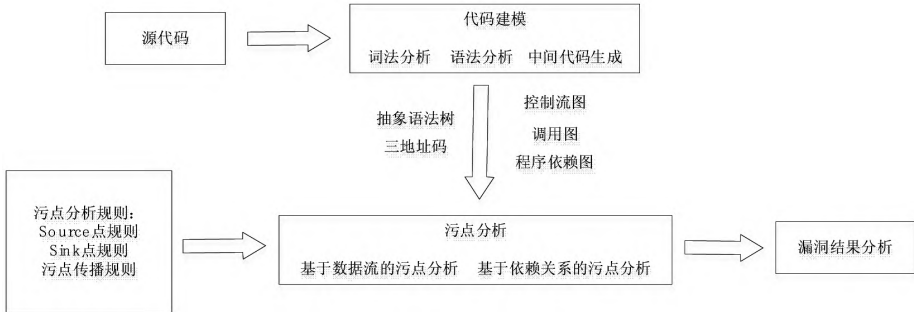


图2 静态信息流跟踪

术,用于检测程序中数据传递和变化的方式,如图1所示。其中,数据流方向性描述了信息在程序中如何传递和演变。通过确定数据流的方向,可以跟踪信息的流动路径,有助于识别潜在的安全风险点。数据流方向性使分析人员能够更清晰地理解程序中信息的传递方式,并定位可能存在漏洞的区域。半格(L)由值集合和交汇运算组成,用于定义元素之间的假序关系。在数据流分析中,半格(L)被用来表示程序执行过程中可能的值范围,帮助确定变量可能的取值情况。通过对值集合进行交汇运算,可以更准确地推断出程序中各个变量可能的取值情况。转移函数集合(F)描述了数据如何从一个状态转移到另一个状态。

1.3 静态信息流跟踪

静态信息流跟踪技术是一种安全分析方法,用于

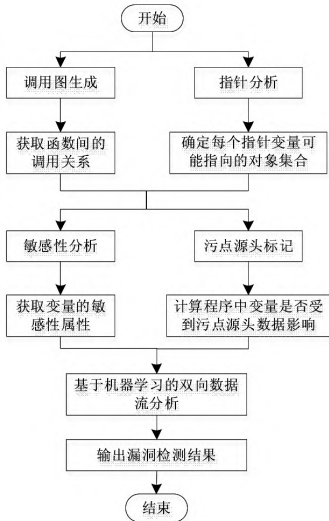


图3 漏洞检测流程

发现程序中数据传播路径的有效性,如图2所示。静态信息流跟踪技术通过对不可信源头引入的数据进行污点标记,并在程序中追踪这些标记在传播路径上是否被清理。这种技术的主要目标是识别污点数据传播路径,以完整描述潜在攻击过程。静态信息流跟踪技术通过对程序中数据传播过程进行细致分析,可以及时发现潜在漏洞并提前进行修复,从而提高系统对各种安全威胁的抵御能力。

2 算法设计

本文提出一种基于机器学习算法的WEB应用程序漏洞检测策略,主要包括生成调用图和指针分析、敏感性分析与标记污点源头和基于机器学习的双向数据流分析等步骤,如图3所示,可以准确高效地实现WEB应用程序漏洞检测。

2.1 生成调用图和指针分析

进行程序的静态漏洞检测时,首先需要生成被分析程序的调用图。调用图是对程序中函数调用关系的图形表示,有助于理解程序结构和函数之间的依赖关系。通过这种图形表示,可以清晰地了解各个函数之间的调用顺序以及数据流动情况。

同时,进行指针分析是为了确定每个指针变量可能指向的对象集合。这种分析通过计算指针之间的指向关系来映射变量到运行时可能指向的对象集合。典型的指针指向关系通过变量的指针指向集合表示,其中存放着运行时变量可能指向的对象。

继而,过程内数据依赖分析旨在建立方法间数据依赖关系摘要,通过逐步追踪方法内部的数据流动路径,并记录方法参数与返回值之间的数据依赖关系。

2.2 敏感性分析与标记污点源头

程序的调用图上标记污点源头、敏感函数和清洁函数是为了识别潜在的安全风险点。污点源头是可能被恶意利用或篡改数据的入口点,敏感函数则是处理重要数据或执行关键操作的函数,而清洁函数则负责验证或处理数据以确保安全性。

敏感性分析是一种逆向的数据流分析方法,用于计算程序中变量的敏感性属性。变量的敏感性属性表示变量是否可能成为敏感函数的敏感参数。半格定义了变量的敏感性属性,包括不敏感和敏感两种类型。对于每个基本块和语句,根据语句类型更新集合和属性值,以传播数据间的敏感性属性。

污点传播则是一种前向的数据流分析方法,用于计算程序中变量是否受到污点源头数据影响。变量的污点属性表示是否被污染。通过半格定义变量的污点属性,并根据语句类型更新集合和属性值来传播数据间的污点属性。

敏感性分析中,定义了一个半格:

$$S_s \subseteq S_u \cup \{\text{inserts, removes}\} \quad (1)$$

式中: S_s 为静态特征集合; S_u 为使用特征;insert 和 remove 分别为其插入和移除操作。

值域集合有:

$$V = P(\text{Var} \times S_s) \quad (2)$$

式中:Var 表示程序中的变量集合。

污点传播中,定义了半格:

$$T_s \subseteq T_u \cup \{\text{tainted, unknown, untainted}\} \quad (3)$$

式中: T_s 为静态特征集合; T_u 为使用特征;tainted、unknown 和 untainted 分别为污染、未知和未污染。默认条件下污点属性初始化为 unknown,污点传播的半格为乘积格,其值域集合有:

$$V = P(\text{Var} \times T_s) \quad (4)$$

通过标记这些关键点并进行相应分析,可以帮助识别潜在安全风险,并进一步加强程序安全性。

2.3 基于机器学习的双向数据流分析

基于机器学习的双向数据流分析是一种利用机器学习算法来跟踪数据流动路径并定位潜在漏洞位置的方法。双向数据流分析同时考虑了正向和反向的数据流传播过程。正向过程关注了从输入源头到潜在

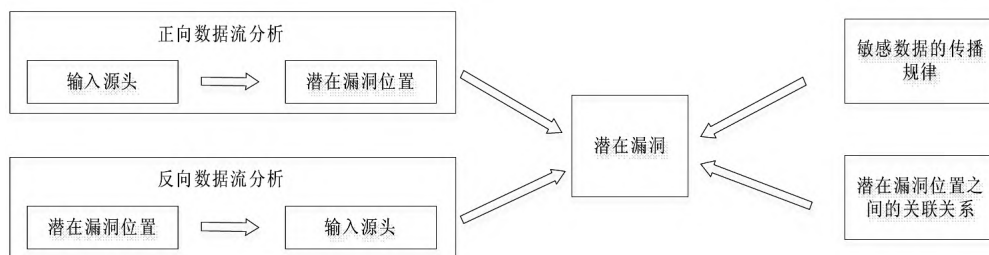


图4 基于机器学习的双向数据流分析

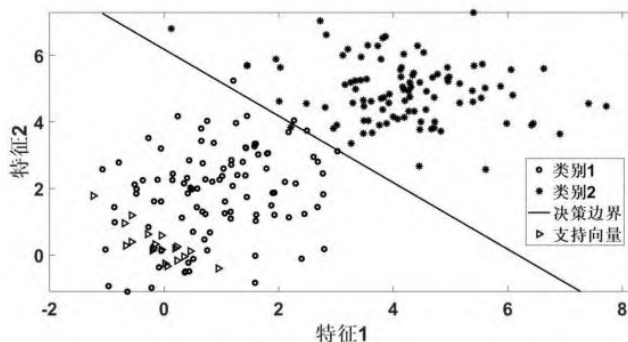


图5 决策边界与散点

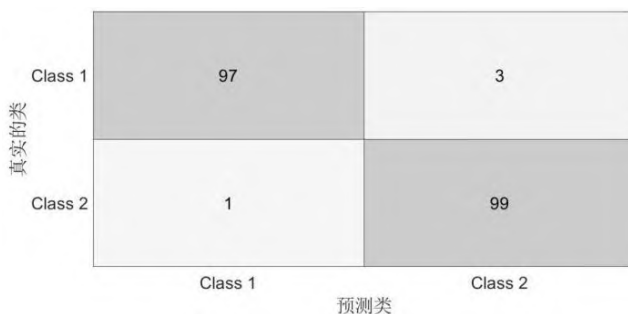


图6 混淆矩阵

漏洞位置的数据传播路径,而反向过程则从潜在漏洞位置追溯回可能的输入源头。

基于模糊 SVM 的双向数据流分析方法,通过结合敏感性分析和污点传播过程,并学习程序中敏感数据的传播规律和潜在漏洞位置之间的关联,从而识别可能存在安全风险的区域,能够更准确地检测并定位潜在安全风险,并提高漏洞检测效率。基于机器学习的双向数据流分析如图4所示。

3 实验验证

3.1 实验环境

实验在 Windows XP SP2 操作系统的 PC 上进行,配置为 2.33GHz Intel Core 2 CPU 和 2GB RAM,以及 Java 标准版运行环境 (Java Standard Edition Runtime Environment, JRE) 1.6.0-23 版本和 256 MB 堆空间。模型利用了包含 200 个漏洞扫描样本的数据

集进行检测,并使用 SVM 算法进行双向数据流分析以对样本进行分类。

3.2 分类结果

基于现有不同类别分类结果的散点图展示了特征一和特征二构成的二维

度平面,如图 5 所示,每个点在散点图中代表一个样本,其位置由特征一(敏感函数)和特征二(污点特征)的水平确定,基于此区分的决策边界能够有效区分不同类别样本。

3.3 混淆矩阵分析

混淆矩阵(图 6)分析显示了模型在不同类别样本上的分类准确性指标。根据混淆矩阵的结果,得到了一个准确率为 98%、真正率为 97%、假负率为 99%的混淆矩阵。这意味着模型在大多数情况下能够正确地对样本进行分类,而且在处理正例和负例时表现良好。准确率高达 98%表明模型在整体上能够准确地分类大多数样本;而真正率和假负率则显示出模型在处理正例和负例时都具有较好的性能。

结束语

本文提出了一种基于机器学习算法的 WEB 应用程序漏洞检测策略,实验环境下,基于 SVM 算法进行双向数据流分析的方法表现出了较高的准确性和稳健性,表明本文所提出的方法可以有效地识别潜在安全风险,并且具有潜力应用于实际系统中以提高漏洞检测效率。

参考文献

- [1]王泽旭,文斌.关键路径预搜索的符号执行智能合约漏洞检测[J].应用科学学报,2024,42(2):364-374.
- [2]冯青文,王丹辉,张德贤.LSTM-SVM 算法下软件潜在溢出漏洞检测仿真[J].计算机仿真,2024,41(2):487-491.
- [3]郑鹏,沙乐天.基于混合分析的 Java 反序列化漏洞检测方法[J].计算机工程,2023,49(12):136-145.
- [4]况博裕,张兆博,杨善权,等.HMFuzzer:一种基于人机协同的物联网设备固件漏洞挖掘方案[J].计算机学报,2024,47(3):703-716.
- [5]徐寅森,李红艳,张子栋.基于机器学习的传感网核心节点漏洞检测仿真[J].计算机仿真,2024,41(3):410-414.
- [6]李鑫,杜景林,陈子文,等.基于双通道的智能合约漏洞检测方法[J].科学技术与工程,2023,23(34):14651-14659.

Machine Learning-based Strategies for WEB Application Vulnerability Detection

Wang Bin, Jiang Mingchu, Zhou Jin, Li Xiaoyu, Chen Zehan

(The 28th Research Institute of China Electronics Technology Group Corporation, Nanjing, China)

Abstract: With the popularity of WEB applications, concerns about their security have increased. Vulnerability detection, as one of the key means to ensure the security of WEB applications, has been highly valued. This article combines a variety of vulnerability detection methods and proposes a machine learning-based strategy for WEB application vulnerability detection. By integrating sensitivity analysis, static information flow tracking, and bidirectional data flow analysis, this article designs a comprehensive vulnerability detection method, which has achieved an excellent performance with an accuracy rate of 98% in the test environment.

Key words: SVM; vulnerability scanning; detection strategy